CIA Part 1 – Questions 178–236

Super Super Hard: Impossible-Level Judgment Traps

CIA Study Prep

October 17, 2026

Instructions

Each question slide is followed by a separate answer/explanation slide.

These are written at "impossible" difficulty: every option is defensible, multiple Standards conflict, and the correct answer turns on a single word or a subtle priority.

Read every qualifier (MOST, LEAST, FIRST, BEST, PRIMARY). The wrong answers are designed to be tempting.

Do not advance until you have committed to an answer.

Q178

Question: A CAE has functional reporting to the audit committee but administrative reporting to the CFO. The CFO is also the executive sponsor of a major ERP implementation that internal audit is currently auditing. The audit committee chair tells the CAE privately that the CFO has asked the chair to "delay the ERP audit until after go-live" and that the chair is "inclined to agree to preserve harmony." The ERP represents 40% of the finance function's transaction volume. Which is the MOST appropriate action for the CAE?

A. Agree to delay, because the audit committee chair has authority over the audit plan and harmony with the CFO supports future cooperation.

B. Document the request and the independence threat, keep the engagement on the approved plan, and escalate the matter formally to the full audit committee (not only the chair).

C. Delay the engagement but perform a limited advisory review of the ERP design to remain engaged.

D. Refer the matter to the external auditor and rely on the external auditor's work to cover the ERP risk.

Q178 – Answer & Explanation

Correct Answer: B

Why: The chair is asking the CAE to accept an independence threat (CFO pressure to delay a material audit) to preserve harmony. Standards 1110/1111/1130/2010 require the CAE to report threats and plan matters to the full audit committee, not merely the chair, and to document the threat. The plan is approved by the committee; a single member cannot override it.

A wrong: "Harmony" is not a valid reason to suppress a material audit; the chair alone does not control the plan.

C wrong: A limited advisory review does not substitute for the required assurance and still succumbs to the delay.

D wrong: External audit referral does not discharge internal audit's responsibility or cure the threat.

Q179

Question: An auditor is testing a key automated three-way-match control. The ITGCs are strong, but the auditor discovers that a "break-glass" super-user account exists that can override the match without a ticket. The account was used 14 times in the year, always by the AP manager, always on the last two business days of the quarter, and all overrides involved invoices from a single vendor. The AP manager states the overrides were "timing differences." The auditor has limited forensic skills but strong data analytics. Which is the MOST appropriate course of action?

A. Conclude the control is effective because ITGCs are strong and the overrides were explained.

B. Treat the pattern (super-user, quarter-end, single vendor) as a high-risk fraud indicator: preserve logs, analyze the vendor, escalate to the CAE/audit committee, and consider recommending a fraud investigation.

C. Re-perform the three-way match manually on the 14 overridden invoices and, if they match, close the matter.

D. Report only the ITGC weakness (break-glass account) and take no further action on the transactions.

Q179 – Answer & Explanation

Correct Answer: B

Why: The pattern—super-user override, quarter-end timing, single vendor—is a textbook fraud red flag (window dressing / fictitious liabilities or payments). Strong ITGCs do not neutralize transaction-level abuse of a privileged account. The auditor must preserve evidence, analyze, escalate, and recommend investigation; re-performing only the 14 invoices misses the point.

A wrong: An explanation is not evidence, and the pattern is high-risk.

C wrong: If the overrides were legitimate timing differences, the match would not have failed; and manual re-performance does not address the pattern.

D wrong: Reporting only the account issue ignores the transactions.

Q180

Question: The CAE is asked by the CEO to lead a "special review" of a competitor's publicly available pricing data to help the sales team win a major contract. The CEO frames it as "competitive intelligence" and says it is "within internal audit's analytical capability." Internal audit's charter is silent on competitive intelligence. Which is the MOST appropriate response?

A. Accept, because the charter is silent and the CEO has authority to direct internal audit's work.

B. Decline, because using internal audit for competitive intelligence is outside the charter, creates objectivity/independence concerns, and may raise legal/ethical issues; refer to the appropriate function and inform the audit committee.

C. Accept, but disclose the engagement in the next audit committee report.

D. Accept only if the data is obtained from public sources and no competitor employees are contacted.

Q180 – Answer & Explanation

Correct Answer: B

Why: Internal audit's scope is defined by its charter (Standard 1000) and must remain within assurance/consulting boundaries that preserve objectivity (Standards 1110/1130). Competitive intelligence for sales is outside the charter, may be unethical/illegal, and would compromise the function's independence. The audit committee should be informed.

A wrong: Charter silence does not authorize any activity the CEO requests.

C wrong: Disclosure after the fact does not cure the scope/independence problem.

D wrong: Public sources do not resolve the charter/ethics issue.

Q181

Question: An auditor is evaluating a revenue arrangement where the company sells goods to a distributor with a "right of return" and "price protection" clause, and separately provides a marketing subsidy to the distributor. The distributor has no physical capacity to store the goods and has historically returned 40% of purchases. Management recognizes revenue at shipment because "legal title passes" and the distributor "has accepted the goods." Which is the MOST appropriate conclusion?

A. Revenue recognition is appropriate because legal title passed and the distributor accepted the goods.

B. Revenue recognition is likely inappropriate; the combination of return rights, price protection, no storage capacity, and a 40% return history indicates the distributor is a conduit and control has not transferred.

C. Revenue recognition is appropriate because the marketing subsidy is a separate transaction.

D. Revenue recognition is appropriate because the distributor is an unrelated party.

Q181 – Answer & Explanation

Correct Answer: B

Why: Substance over form. Return rights, price protection, no storage capacity, and a 40% return history together indicate the "sale" is a channel-stuffing/financing arrangement, and control has not transferred. Legal title and acceptance are not determinative.

A wrong: Legal title/acceptance are not sufficient when substance indicates no transfer.

C wrong: The subsidy is part of the arrangement and affects substance.

D wrong: Unrelated-party status does not cure the return/price-protection issues.

Q182

Question: The CAE is evaluating the internal audit activity's conformance. The activity has a QAIP, ongoing internal assessments, and an external assessment performed 4 years ago. However, the external assessor was a former partner of the CAE's spouse, and the CAE did not disclose this relationship to the audit committee. The assessment concluded "generally conforms." Which is the MOST accurate statement?

A. The activity conforms because the external assessment was performed within five years and concluded generally conforms.

B. The external assessment's independence is impaired by the undisclosed relationship; the CAE should disclose the relationship, and the assessment's conclusion may not be reliable for conformance purposes.

C. The relationship is irrelevant because the assessor is qualified.

D. The activity conforms because the audit committee has not objected.

Q182 – Answer & Explanation

Correct Answer: B

Why: Standards 1312 and the QAIP require the external assessor to be independent and qualified, and the CAE to disclose conflicts. A former partner of the CAE's spouse is a significant independence threat that must be disclosed; the conclusion may be unreliable.

A wrong: Timing and conclusion do not cure the independence impairment.

C wrong: Qualification does not equal independence.

D wrong: Absence of objection is not approval of an undisclosed conflict.

Q183

Question: An auditor is testing the organization's controls over the financial close. The controller has the ability to post manual journal entries and then "hide" them from the standard ledger view using a system configuration. The controller used this 9 times in the year, all entries increased revenue and reduced reserves, all were reversed in the following year, and all lacked support. The CFO states the entries were "quarter-end estimates." Which is the MOST appropriate conclusion and action?

A. Controls are effective because the entries were reversed in the following year.

B. Controls are deficient and the pattern is a serious fraud indicator (hidden entries, revenue increase, reserve reduction, no support, reversal); preserve evidence, escalate to the CAE/audit committee, and recommend investigation.

C. The auditor should accept the CFO's explanation because quarter-end estimates are common.

D. The auditor should report only the system configuration weakness and not the entries.

Q183 – Answer & Explanation

Correct Answer: B

Why: Hidden entries that increase revenue, reduce reserves, lack support, and are reversed are classic earnings-management/fraud indicators (cookie-jar reserves, improper estimates). Reversal does not legitimize them. The pattern requires escalation and investigation.

A wrong: Reversal does not cure the improper recognition.

C wrong: "Common" estimates do not explain hidden, unsupported, revenue-increasing entries.

D wrong: Reporting only the configuration ignores the substance.

Q184

Question: The audit committee asks the CAE to assess whether the organization's ethics program is effective. The program includes a code of conduct, annual acknowledgments, and a hotline. However, the hotline is managed by the general counsel, who reports to the CEO; the audit committee does not receive hotline reports; and no ethics investigations were opened last year despite three hotline calls. Which is the MOST significant weakness?

A. The existence of a code of conduct.

B. The hotline's reporting line to the general counsel/CEO and the audit committee's lack of visibility, combined with no investigations of three calls.

C. The annual acknowledgments.

D. The absence of ethics training.

Q184 – Answer & Explanation

Correct Answer: B

Why: The hotline must be independent and visible to the audit committee; three calls with no investigations suggests suppression. This is the most significant governance/ethics weakness among the options.

A wrong: A code is a strength.

C wrong: Acknowledgments are a basic strength.

D wrong: Training is relevant but less significant than suppressed reports.

Q185

Question: An auditor is evaluating the organization's use of a third-party AI model for credit decisions. The vendor will not disclose the model logic, the model was not validated by the organization, and the organization cannot explain adverse action decisions to regulators. The model is used for 60% of consumer credit decisions. Which is the MOST appropriate conclusion?

A. The model is acceptable because it is vendor-provided and widely used in the industry.

B. The model creates significant model risk, compliance risk (adverse action explainability), and reputational risk; the organization must validate, document, and ensure explainability, and the auditor should report the gap.

C. The model is acceptable because the vendor is responsible for its performance.

D. The auditor should not assess vendor models.

Q185 – Answer & Explanation

Correct Answer: B

Why: Use of an opaque AI model for consumer credit without validation or explainability creates significant model, compliance, and reputational risk (adverse action notice requirements). Vendor responsibility does not transfer the organization's obligations.

A wrong: Industry use does not cure the validation/explainability gap.

C wrong: The organization remains responsible for its decisions.

D wrong: Vendor models are within internal audit's scope.

Q186

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of a major acquisition. The board approved the deal based on a 10-page management summary, received the summary 24 hours before the meeting, and did not receive the valuation model or the risk assessment. The deal represents 35% of the organization's assets. Which is the MOST appropriate conclusion?

A. Board oversight is effective because the board approved the deal.

B. Board oversight is likely ineffective; a 10-page summary, 24-hour notice, and no valuation/risk information for a 35%-of-assets deal impair informed oversight.

C. Board oversight is effective because management is accountable for the deal.

D. The auditor should not assess board oversight of acquisitions.

Q186 – Answer & Explanation

Correct Answer: B

Why: Informed board oversight requires sufficient, timely information, especially for a material acquisition. A short summary, 24-hour notice, and no valuation/risk materials are significant governance weaknesses.

A wrong: Approval without adequate information is not effective oversight.

C wrong: Management accountability does not replace board oversight.

D wrong: Board oversight of acquisitions is a core governance area.

Q187

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q187 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q188

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q188 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q189

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q189 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q190

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q190 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q191

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q191 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q192

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q192 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q193

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q193 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q194

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q194 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q195

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q195 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q196

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q196 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q197

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q197 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q198

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q198 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

Q199

Question: An auditor is assessing the organization's controls over the use of spreadsheets in financial reporting. The auditor finds that a critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

Q199 – Answer & Explanation

Correct Answer: B

Why: Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

A wrong: Common use does not reduce risk.

C wrong: Spreadsheets can be used with adequate controls.

D wrong: Spreadsheet controls are a valid audit area.

Q200

Question: The CAE is evaluating the organization's risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

Q200 – Answer & Explanation

Correct Answer: B

Why: Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

A wrong: CIO accountability alone is insufficient.

C wrong: All projects require risk management.

D wrong: IT project risk is a core audit area.

Q201

Question: An auditor is testing the organization's controls over journal entries. The auditor finds that 20 large manual entries were posted at year-end by the controller with descriptions such as "reclass" and "true-up," and that supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

Q201 – Answer & Explanation

Correct Answer: B

Why: Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

A wrong: Authorization does not eliminate the need for support.

C wrong: Internal audit should not alter records.

D wrong: Year-end adjustments require documentation.

Q202

Question: The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

Q202 – Answer & Explanation

Correct Answer: B

Why: KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

A wrong: Financial/customer metrics alone are insufficient.

C wrong: KRIs are an important monitoring tool.

D wrong: Internal audit assesses risk monitoring.

Q203

Question: An auditor is evaluating the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q203 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q204

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q204 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q205

Question: An auditor is testing the organization's controls over the use of artificial intelligence (AI) in credit decisions. The auditor finds that the AI model was developed by an external vendor, has not been validated, and that management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

Q205 – Answer & Explanation

Correct Answer: B

Why: AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

A wrong: Vendor development does not eliminate the need for validation.

C wrong: AI models require validation.

D wrong: AI risk is a core internal audit area.

Q206

Question: The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

Q206 – Answer & Explanation

Correct Answer: B

Why: Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

A wrong: Independence alone does not resolve self-review for reports about internal audit.

C wrong: Internal audit management is not inherently ineffective.

D wrong: Internal audit can manage hotlines with safeguards.

Q207

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the controller prepares, reviews, and posts consolidation entries, and that the controller has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q207 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q208

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q208 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q209

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q209 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q210

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q210 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q211

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q211 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q212

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q212 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q213

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q213 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q214

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q214 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q215

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q215 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q216

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q216 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q217

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q217 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q218

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q218 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

Q219

Question: An auditor is assessing the organization's controls over the use of spreadsheets in financial reporting. The auditor finds that a critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

Q219 – Answer & Explanation

Correct Answer: B

Why: Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

A wrong: Common use does not reduce risk.

C wrong: Spreadsheets can be used with adequate controls.

D wrong: Spreadsheet controls are a valid audit area.

Q220

Question: The CAE is evaluating the organization's risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

Q220 – Answer & Explanation

Correct Answer: B

Why: Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

A wrong: CIO accountability alone is insufficient.

C wrong: All projects require risk management.

D wrong: IT project risk is a core audit area.

Q221

Question: An auditor is testing the organization's controls over journal entries. The auditor finds that 20 large manual entries were posted at year-end by the controller with descriptions such as "reclass" and "true-up," and that supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

Q221 – Answer & Explanation

Correct Answer: B

Why: Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

A wrong: Authorization does not eliminate the need for support.

C wrong: Internal audit should not alter records.

D wrong: Year-end adjustments require documentation.

Q222

Question: The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

Q222 – Answer & Explanation

Correct Answer: B

Why: KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

A wrong: Financial/customer metrics alone are insufficient.

C wrong: KRIs are an important monitoring tool.

D wrong: Internal audit assesses risk monitoring.

Q223

Question: An auditor is evaluating the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q223 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q224

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q224 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q225

Question: An auditor is testing the organization's controls over the use of artificial intelligence (AI) in credit decisions. The auditor finds that the AI model was developed by an external vendor, has not been validated, and that management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

Q225 – Answer & Explanation

Correct Answer: B

Why: AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

A wrong: Vendor development does not eliminate the need for validation.

C wrong: AI models require validation.

D wrong: AI risk is a core internal audit area.

Q226

Question: The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

Q226 – Answer & Explanation

Correct Answer: B

Why: Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

A wrong: Independence alone does not resolve self-review for reports about internal audit.

C wrong: Internal audit management is not inherently ineffective.

D wrong: Internal audit can manage hotlines with safeguards.

Q227

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the controller prepares, reviews, and posts consolidation entries, and that the controller has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q227 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q228

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q228 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q229

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q229 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q230

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q230 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q231

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q231 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q232

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q232 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q233

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q233 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q234

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q234 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q235

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q235 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q236

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q236 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

End

End of Questions 178–236

Review, repeat, and mark weak areas.